

FIELD MANUAL · BETA EXAM · MAY 2026 · REPLACES AZ-500

SC-500

Cloud and AI Security Engineer Associate

Implementing End-to-End Security Controls for Cloud and AI Workloads — a complete 130-slide visual study system: every domain, every objective, wired-together diagrams, and a memory hook for each corner of the blueprint.

700/1000

PASS SCORE

100 MIN

DURATION

40–60

QUESTIONS

PEARSON VUE

PROVIDER

What's inside this manual

00	Orientation Exam facts, audience, strategy, how to use this deck	10 SLIDES
01	Identity, Access & Governance PIM · Conditional Access · Key Vault · RBAC · Policy	25 SLIDES
02	Storage, Databases & Networking Firewalls · SQL security · NSG/ASG · Private Link · VWAN	23 SLIDES
03	Secure Compute + AI Security Copilot · Entra Agent ID · Foundry · VMs · Containers · Apps	29 SLIDES
04	Security Posture & Monitoring Defender for Cloud · Sentinel · Security Copilot	18 SLIDES
05	Rapid-Recall Drill 15 closed-book questions	16 SLIDES
06	Glossary Every acronym this exam assumes you speak fluently	8 SLIDES
07	Exam-Day Strategy Final checklist and mindset	1 SLIDES

Why SC-500 exists

Microsoft retired the idea that "cloud security" and "AI security" are separate jobs. SC-500 merges them into one Associate-level credential.

1 Released in beta

SC-500 entered beta in May 2026 as the direct successor to AZ-500: Microsoft Azure Security Technologies.

2 AZ-500 retires 31 Aug 2026

After that date you can no longer earn or renew AZ-500. If you're starting fresh today, study SC-500 — your AZ-500 runway is short.

3 First AI-native security exam

SC-500 is the first Microsoft security exam to formally test AI workload security as its own discipline, not a footnote.

Exam quick facts

Detail	Value
Exam code	SC-500
Official title	Implementing End-to-End Security Controls for Cloud and AI Workloads
Certification level	Associate
Pass score	700 out of 1000
Duration	100 minutes
Question count	Approximately 40–60
Question types	Multiple choice, multiple response, drag-and-drop, case study
Delivery provider	Pearson VUE
Validity	Renews annually, free via Microsoft Learn
Replaces	AZ-500 (retiring 31 August 2026)

Beta-window caveat: Microsoft beta exams typically take about ten weeks to score after the beta closes — plan your job search timeline accordingly.

Who this exam is for

The audience profile is explicit: engineers implementing controls across identity, network, application, data, and compute — and now, AI workloads.



Azure & hybrid experience

Comfortable administering compute, network, and storage across Azure and on-premises.



Entra ID working knowledge

Directory structure, conditional access, PIM, and identity fundamentals.



M365 administration

The AI-security objectives lean heavily on Microsoft 365, Purview, and Copilot familiarity.



SecOps fundamentals

Comfortable with alerts, incidents, and posture management as daily workflow.

How the exam is weighted



Domain 2 carries the most weight, but Domain 3's AI-security bullets deserve outsized study time — see next slide.

The single biggest study-time trap

- Domain 3 (Secure Compute) reads as 20–25% of the exam — the same as every other domain.
- But roughly half of Domain 3's objectives are entirely new AI-security material: SharePoint overexposure, Purview DSPM, Entra Agent ID, Foundry AI Gateway, Defender for AI Service.
- None of that exists anywhere on AZ-500 — so even seasoned Azure security engineers are starting from zero here.
- Everything else in Domain 3 (VMs, containers, App Service) is largely familiar AZ-500 territory.

EXAM TIP

Budget roughly 25–30% of your total study hours on the AI-security sub-domain alone, even though its blueprint weight looks modest. This manual gives it 34 dedicated slides for exactly that reason.

How to use this manual



Mnemonic slides

One per domain — a short acronym anchored to a vivid image. Say it out loud, don't just read it.



Flashcard grids

Cover the answer half with your hand before reading it. If you hesitate, that card goes back into rotation.



Exam-tip callouts

Gold boxes flag the pattern the real exam rewards. Red boxes flag the trap most candidates fall into.



Diagrams

Every process (identity flow, AI pipeline, Sentinel pipeline) is drawn left-to-right in the order it actually happens.

Question formats you'll actually see

Format	What to expect
Multiple choice	One correct answer among four options — the most common format
Multiple response	Select all options that apply — partial credit is not given, so read carefully
Drag-and-drop	Match items to categories or sequence steps in the correct order
Case study	A longer scenario with several related questions — re-read the scenario for each question, details shift focus

Case studies reward re-reading. A detail that seemed irrelevant to question one is often the key to question three.

Where SC-500 leads next



SC-100 — Cybersecurity Architect

The Expert-level destination after SC-500. Broader, design-focused, less hands-on configuration.



SC-200 — Security Operations Analyst

Deepens Sentinel and Defender XDR content this manual only summarizes.



SC-300 — Identity and Access Administrator

Deepens the Entra, PIM, and Conditional Access content that Domain 1 only skims.

1

DOMAIN 1

Identity, Access & Governance

Who gets in, how they prove it, what they're allowed to touch, and who's watching the watchers.

20–25% OF EXAM

Privileged Identity Management (PIM)

- ▶ PIM converts standing admin rights into just-in-time rights: a user activates a role for a fixed window instead of holding it permanently.
- ▶ Activation can require approval, justification, and MFA re-confirmation before the role goes live.
- ▶ Every activation is logged — full audit trail of who had which role, when, and why.
- ▶ PIM governs both Azure resource roles and Microsoft Entra roles — it is not limited to the directory.

EXAM TIP

If a scenario describes an admin who "only needs Contributor for two hours to finish a deployment," the answer is almost always a PIM eligible-role activation — not a permanent assignment, and not a brand-new custom role.

Conditional Access

- An if/then policy engine: signals in (user, group, device, location, sign-in risk), controls out (block, require MFA, require compliant device, require app protection).
- Policies are additive — if any applicable policy blocks, access is blocked, regardless of what other policies allow.
- Named locations, device platforms, and client apps are common conditions candidates overlook.
- Report-only mode lets you validate a policy's real-world impact before it enforces anything.

COMMON TRAP

Don't confuse Conditional Access (dynamic, signal-based) with static RBAC role assignment — CA decides whether a sign-in is allowed at all; RBAC decides what an already-signed-in identity can do.

MFA & passwordless authentication

- ▶ **Multi-factor authentication methods: Microsoft Authenticator, SMS/voice (weaker, being deprecated in many orgs), FIDO2 security keys.**
- ▶ **Passwordless is the preferred end state on this exam, not a bolt-on extra: Authenticator phone sign-in, FIDO2 keys, Windows Hello for Business.**
- ▶ **Authentication methods policy (not the legacy MFA portal) is the modern configuration surface Microsoft expects you to know.**
- ▶ **Combine with Conditional Access to require a specific strength of authentication for sensitive actions.**

App Registration vs. Enterprise Application

App Registration

- The global definition of an application in Microsoft Entra ID.
- Owns the app's client ID, redirect URIs, and API permission declarations.
- Created once per app, even if the app is used across many tenants.

Enterprise Application

- The tenant-local service principal instance of that app.
- This is the object Conditional Access policies and permission grants actually attach to.
- One app registration can have an enterprise application object in every tenant that installs it.

OAuth permission grants & consent

- ▶ User consent settings decide whether individual users can approve an app's permission requests themselves.
- ▶ Admin consent workflow lets a designated reviewer approve requests centrally instead of leaving it to end users.
- ▶ "Illicit consent grant" attacks trick a user into approving a malicious app's OAuth request — the fix is tightening consent settings, not deleting the compromised account.
- ▶ Review existing OAuth grants periodically; a forgotten, over-permissioned app is a standing risk.

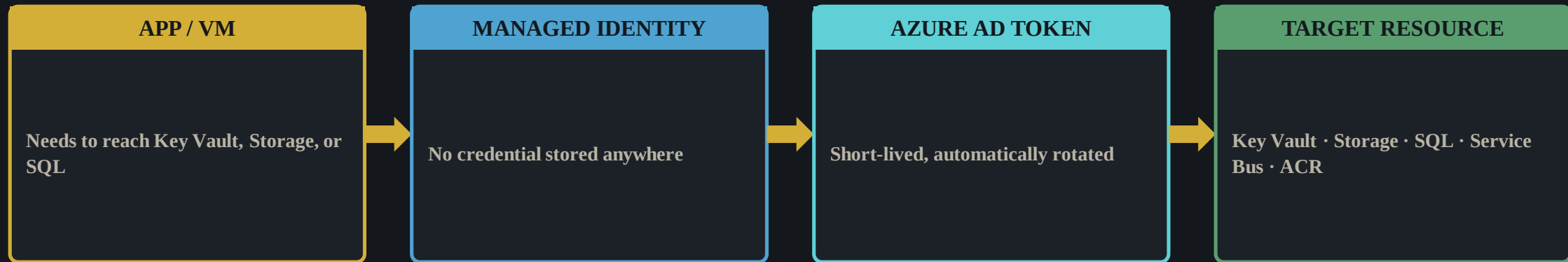
COMMON TRAP

When a scenario describes a phishing-style consent attack, the correct remediation targets the app's OAuth grant and the tenant's consent policy — not a password reset, which does nothing against a token-based attack.

Managed identities — the core pattern

- ▶ A managed identity is an identity Azure AD manages for you automatically — no credential to create, rotate, or store.
- ▶ System-assigned: lifecycle tied to one resource; deleted automatically when the resource is deleted; strictly 1:1.
- ▶ User-assigned: a standalone object; can be attached to many resources; survives deletion of any single resource.
- ▶ Resources request an Azure AD token using the managed identity, then present that token to the target service.

The pattern the exam rewards



Almost every "correct answer" that instead mentions a stored connection string or access key is wrong. Drill this flow until it's automatic.

Azure Key Vault — deploy & configure

- ▶ **Access model choice:** Azure RBAC (recommended, unified with the rest of Azure) vs. legacy vault access policies.
- ▶ **Network controls:** firewall rules restricting to specific IPs/VNets, or a private endpoint removing public exposure entirely.
- ▶ **Soft-delete and purge protection** guard against accidental or malicious permanent deletion of vault contents.
- ▶ **Logging via diagnostic settings** feeds Key Vault activity into Sentinel or Log Analytics for investigation.

Keys, secrets, and certificates

- ▶ **Keys** — cryptographic keys for encrypt/decrypt or sign/verify operations, optionally backed by an HSM.
- ▶ **Secrets** — arbitrary sensitive strings: connection strings, API tokens, passwords.
- ▶ **Certificates** — full lifecycle management including auto-renewal and integration with issuing CAs.
- ▶ **Each object type carries its own fine-grained permission model** — a principal can be scoped to secrets only, keys only, or any combination.

Key Vault threat protection

Defender CSPM — secret scanning

- Scans across your environment — code repos, VM disks, storage — for secrets living outside Key Vault.
- Surfaces plaintext credentials as a posture finding, not a runtime alert.
- Part of the broader Cloud Security Posture Management workload plan.

Defender for Key Vault

- Runtime threat detection on the vault itself.
- Flags unusual access patterns, suspicious operations, and anomalous authentication attempts against vault contents.
- A distinct Defender plan you must explicitly enable per subscription.

Azure Policy

- ▶ Built-in definitions cover the vast majority of common compliance needs — start there before writing custom.
- ▶ Custom definitions use JSON rule logic to evaluate and act on resource properties.
- ▶ Effects: Deny (block non-compliant deployment), Audit (flag but allow), Append/Modify (auto-correct), DeployIfNotExists (remediate automatically).
- ▶ Initiatives group multiple policies into one assignable bundle — this is how regulatory frameworks are delivered.

Regulatory compliance via Defender for Cloud

- ▶ The compliance dashboard maps your environment's actual configuration against named standards: NIST, ISO 27001, PCI-DSS, and more.
- ▶ Each standard decomposes into individual controls, each control into specific, actionable recommendations.
- ▶ You can add or remove standards depending on which frameworks your organization is actually obligated to meet.
- ▶ This is a continuously evaluated score, not a point-in-time audit — configuration drift shows up immediately.

Resource locks

CanNotDelete

- Blocks deletion of the locked resource.
- Configuration changes and updates are still allowed.
- Good for protecting production resources from accidental removal during routine changes.

ReadOnly

- Blocks deletion AND blocks configuration changes.
- Effectively freezes the resource entirely.
- Use sparingly — it can break automated processes that expect to update tags or settings.

RBAC — built-in and custom roles

- ▶ Built-in roles (Owner, Contributor, Reader, and hundreds of resource-specific roles) cover most real-world needs.
- ▶ Custom roles let you assemble a precise permission set when no built-in role fits — defined via JSON with allowed/denied actions.
- ▶ RBAC spans two separate systems: Azure resource roles (subscriptions, resource groups, resources) and Microsoft Entra roles (directory-level administration).
- ▶ Role assignments can be scoped at management group, subscription, resource group, or individual resource level.

Remediating overprivileged access

- ▶ Access reviews — periodic, scheduled prompts asking "does this person still need this role?" with automatic removal on no response.
- ▶ Entra ID's built-in insights can surface unused permissions within an assigned role.
- ▶ Least privilege is the exam's default correct answer: when two roles both technically work, the narrower one wins.
- ▶ Overprivileged service principals (not just human users) are an equally common exam scenario.

EXAM TIP

Whenever a question offers a broad built-in role alongside a narrower custom role and both technically satisfy the requirement, the narrower, least-privilege option is the intended answer.

Backup security

- ▶ **Soft delete on Azure Backup retains deleted backup data for a recovery window even after a deletion attempt.**
- ▶ **Multi-user authorization (MUA) requires a second, independent approver before critical backup operations (like stopping backup or deleting data) can proceed.**
- ▶ **These controls specifically defend against ransomware scenarios where an attacker with resource access tries to destroy your recovery points.**
- ▶ **Backup security is evaluated separately from backup existence — having backups isn't the same as having protected backups.**

Security controls via infrastructure as code

- Bake policy and compliance checks into ARM, Bicep, or Terraform pipelines rather than fixing configuration drift after deployment.
- Pre-deployment validation (what-if analysis, policy compliance checks) catches violations before resources ever exist.
- IaC scanning tools can catch hard-coded secrets, missing encryption settings, or overly permissive network rules at the pull-request stage.
- This shifts governance left — from reactive posture management to preventive pipeline gates.

Key Vault access — RBAC vs. access policies

Model	How it works	Exam framing
Azure RBAC (recommended)	Role assignments unified with the rest of Azure's permission model	Preferred answer whenever both options are offered
Vault access policies (legacy)	Vault-specific permission model, separate from Azure RBAC entirely	Still valid, but treated as the older pattern

When a scenario needs consistent, auditable permissions across Key Vault and every other Azure resource, Azure RBAC is almost always the intended answer.

Conditional Access — common policy patterns

- ▶ **Require MFA for all users when accessing sensitive apps — the most common baseline policy.**
- ▶ **Block legacy authentication entirely, since legacy protocols can't enforce MFA at all.**
- ▶ **Require a compliant or hybrid-joined device for admin-role sign-ins specifically.**
- ▶ **Require sign-in risk to be low or medium before granting access, driven by Entra ID Protection signals.**

COMMON TRAP

A named location or trusted IP range makes a sign-in more trusted — it does not, by itself, grant access. Conditional Access still evaluates every other applicable policy.

Memory Hook

🚩 G.A.T.E. — the four locks on Domain 1

Picture a castle GATE: nobody crosses without clearing all four checkpoints.



Governance — Policy, RBAC, Resource Locks, Infrastructure as Code, Backup security



Access proofs — Conditional Access, MFA, Passwordless authentication



Trusted identities — Managed Identities, App Registrations, Enterprise Apps



Encrypted secrets — Key Vault, Defender CSPM secret scanning, Defender for Key Vault

Flashcards — round 1

Q

CanNotDelete vs. ReadOnly lock — which one blocks a config change?

A

ReadOnly. CanNotDelete only stops deletion; updates still work.

Q

System-assigned or user-assigned MI for five VMs sharing one identity?

A

User-assigned — it's a standalone, reusable object across resources.

Q

Where do App Registration and Enterprise App actually diverge?

A

App Registration = global app definition. Enterprise App = tenant-local service principal that policies attach to.

Q

Which tool finds secrets left in code instead of Key Vault?

A

Defender CSPM secret scanning.

Flashcards — round 2

Q

Admin needs Contributor for exactly two hours — best control?

A

PIM eligible-role activation, time-boxed and logged.

Q

Fastest fix for an illicit OAuth consent grant attack?

A

Revoke the grant and tighten tenant consent settings — not a password reset.

Q

Which backup control stops an attacker from deleting your recovery points?

A

Multi-user authorization (MUA), paired with soft delete.

Q

Two roles both satisfy a requirement — which does the exam prefer?

A

The narrower, least-privilege option, always.

Quick quiz — Domain 1

1. What replaces a stored connection string in nearly every correct answer? → *A managed identity token flow*
2. Which Entra capability enforces sign-in-time conditions like device compliance? → *Conditional Access*
3. Which object type in Key Vault supports auto-renewal via a CA? → *Certificates*
4. Which policy effect auto-corrects a non-compliant resource? → *DeployIfNotExists / Modify*
5. Which role system covers directory-level administration, distinct from resource RBAC? → *Microsoft Entra roles*

Domain 1 — what to remember



Standing privilege is the enemy — PIM, least-privilege RBAC, and managed identities all exist to eliminate it.



Conditional Access decides whether a sign-in happens at all; RBAC decides what it can do once it's in.



Key Vault's three object types (keys, secrets, certificates) each carry independent permissions and independent Defender coverage.



Governance controls — Policy, locks, IaC checks — are how you enforce all of the above at scale instead of resource-by-resource.

2

DOMAIN 2

Storage, Databases & Networking

The heaviest domain on the exam — data at rest, data in motion, and the walls around both.

25–30% OF EXAM

Storage account security

- ▶ **Storage firewall rules restrict access to specific IP ranges or VNets, denying the public internet by default.**
- ▶ **Access policies govern Shared Access Signatures (SAS) — scope, permitted operations, expiry, and revocation.**
- ▶ **Private endpoints extend the same private-by-default pattern used elsewhere in Azure to storage accounts.**
- ▶ **Encryption at rest is on by default; the real exam focus is access control layered on top of it.**

Defender for Storage

- ▶ **Malware scanning runs against blobs on upload, before anything downstream can consume infected content.**
- ▶ **Sensitive-data threat detection flags activity touching data classified as sensitive by Purview.**
- ▶ **Anomalous access alerts surface unusual patterns — access from unfamiliar locations, unusual volume, or unexpected identities.**
- ▶ **Enabled per-storage-account or per-subscription as a Defender for Cloud workload protection plan.**

Azure SQL platform-level security

- ▶ **Transparent Data Encryption (TDE) encrypts data files at rest automatically, with no application changes.**
- ▶ **Always Encrypted goes further — data stays encrypted even in memory and in query results, keys never reach the database engine.**
- ▶ **Microsoft Entra authentication replaces SQL logins with centrally managed identities — eliminates a whole class of credential-sprawl risk.**
- ▶ **Dynamic data masking limits what non-privileged users see in query results without altering the underlying stored data.**

Database auditing & Defender for Databases

Database auditing

- ▶ Applies to both Azure SQL Database and SQL Managed Instance.
- ▶ Logs can route to a storage account, Log Analytics workspace, or Event Hub.
- ▶ Captures query activity, schema changes, and access patterns for later investigation.

Defender for Databases

- ▶ Covers SQL, Cosmos DB, and open-source relational engines (MySQL, PostgreSQL, MariaDB).
- ▶ Flags SQL injection attempts, anomalous logins, and known vulnerability findings.
- ▶ A distinct workload protection plan you enable per resource type.

NSG and ASG

- ▶ **A Network Security Group (NSG) is the rule set: allow/deny rules evaluated by priority, applied to a subnet or a network interface.**
- ▶ **An Application Security Group (ASG) is a logical grouping of VM NICs — rules can target a named group instead of hard-coded IP addresses.**
- ▶ **Rules are stateful — permitting inbound traffic automatically permits the matching return traffic.**
- ▶ **Default rules deny all inbound from the internet and allow all outbound and intra-VNet traffic — know what changes when you add custom rules.**

Azure Virtual Network Manager

- Centralizes network policy and connectivity configuration across many VNets, potentially spanning multiple subscriptions.
- Network groups let you target policy at a logical collection of VNets rather than configuring each one individually.
- Security admin rules apply globally and can override individual NSG rules — useful for enforcing a baseline that local teams can't loosen.
- Connectivity configurations can establish mesh or hub-and-spoke topology declaratively.

Azure Virtual WAN & secured hubs

- ▶ **Virtual WAN provides a managed hub-and-spoke backbone connecting VNets, branches, and remote users.**
- ▶ **A secured hub integrates Azure Firewall directly into the hub, giving you centralized inspection of hub-to-branch and branch-to-branch traffic.**
- ▶ **Simplifies large-scale topologies that would otherwise require manually peered VNets and separately managed firewalls.**
- ▶ **Route tables and routing intent policies determine whether traffic is forced through the security appliance.**

VPN connections

- ▶ **Site-to-site VPN connects an on-premises network to a VNet over an encrypted IPsec tunnel.**
- ▶ **Point-to-site VPN connects an individual client machine directly to a VNet.**
- ▶ **VPN Gateway SKUs determine throughput and the number of supported tunnels — an exam-relevant sizing decision.**
- ▶ **ExpressRoute is the private, non-internet alternative for organizations needing guaranteed bandwidth and lower latency (contrast, not deep-dived here).**

Microsoft Entra Private Access

- ▶ Zero-trust, identity-aware access to private applications and resources — no traditional VPN client required.
- ▶ Every access request is evaluated against Conditional Access, not just a one-time tunnel authentication.
- ▶ Granular, per-application access replaces the all-or-nothing network reachability a classic VPN grants.
- ▶ Part of the broader Global Secure Access suite alongside Internet Access.

EXAM TIP

"Remote worker needs access to exactly one internal app, nothing else on the network" is the exam's signature phrase for Microsoft Entra Private Access — not a VPN.

Private endpoints & Private Link

- ▶ A private endpoint gives a PaaS service (Storage, SQL, Key Vault, and more) a private IP address inside your VNet.
- ▶ Private Link is the underlying platform capability that makes private endpoints possible across subscriptions and even across tenants.
- ▶ Traffic to a privately-linked service never traverses the public internet, even though the service itself is multi-tenant infrastructure.
- ▶ DNS configuration (private DNS zones) is a frequent practical gotcha — without it, name resolution still points to the public endpoint.

Azure Firewall

- ▶ A managed, stateful firewall-as-a-service operating at Layer 3 through Layer 7.
- ▶ Threat intelligence-based filtering can automatically block traffic to and from known malicious IPs and domains.
- ▶ Application rules filter by FQDN; network rules filter by IP, port, and protocol — know when each applies.
- ▶ Deploys standalone or, more commonly on the exam, inside a Virtual WAN secured hub for centralized inspection.

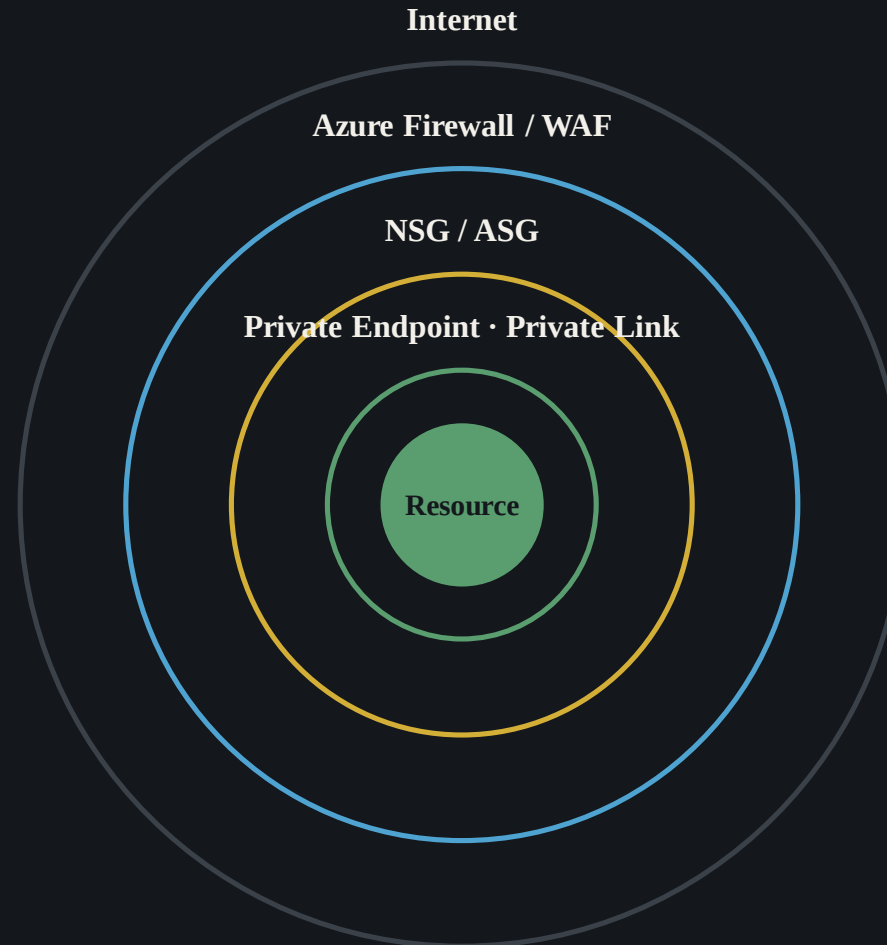
Azure Network Watcher

- ▶ **Effective security rules** shows the actual combined result of every NSG rule applied to a NIC — not just what one NSG says in isolation.
- ▶ **NSG flow logs** record accepted and denied traffic for later analysis or SIEM ingestion.
- ▶ **Connection troubleshoot** and **IP flow verify** diagnose reachability problems between two specific endpoints.
- ▶ **Topology view** visualizes the actual deployed network graph, useful for spotting unintended connectivity.

EXAM TIP

"Prove which rule is actually blocking this traffic" is the exam's phrase for Network Watcher's effective security rules — not the NSG's rule list read in isolation.

Defense in depth, drawn as rings



Outer rings filter broadly; inner rings lock PaaS traffic down to private IPs only. Every control from this domain has a place on this diagram.

The full network toolbox, side by side

Control	What it does	Think of it as...
NSG / ASG	L3/L4 allow-deny rules on subnets/NICs	Room-by-room door locks
Virtual Network Manager	Central policy across many VNets	Building-wide access policy
Virtual WAN (secured hub)	Hub-and-spoke backbone with integrated firewall	Airport hub with security checkpoint
VPN connections	Encrypted site-to-site / point-to-site tunnels	Private tunnel between buildings
Entra Private Access	Zero-trust, identity-aware app access, no VPN client	ID-checked doorway, not a tunnel
Private Endpoint / Link	Private IP for a PaaS service inside your VNet	Unlisted line for the service
Azure Firewall	Managed, stateful L3–L7 firewall + threat intel	The building's main security desk
Network Watcher	Diagnostics — effective rules, flow logs, topology	The building's CCTV & blueprints

Decision tree — choosing the right boundary

- ▶ "User needs access to one internal app" → Microsoft Entra Private Access.
- ▶ "PaaS service must never touch the public internet" → Private Endpoint / Private Link.
- ▶ "Need centralized, inspectable egress across a hub-and-spoke topology" → Azure Firewall in a secured Virtual WAN hub.
- ▶ "Need to prove which rule is actually blocking traffic" → Network Watcher effective security rules.

COMMON TRAP

The exam frequently offers a VPN and Entra Private Access as two options for the same scenario. If the requirement is app-specific access rather than full network reachability, Private Access is almost always the better-fit answer.

SAS tokens — know the four types

SAS type	Scope	Typical use
User delegation SAS	Secured with Entra credentials	Recommended — most secure option
Service SAS	Secured with the storage account key	One service, narrower blast radius than account key
Account SAS	Secured with the storage account key	Broadest scope — multiple services at once
Ad hoc vs. stored access policy	Defines expiry/permissions inline or via a reusable policy	Stored policies allow centralized revocation

User delegation SAS is the exam's preferred answer whenever the scenario allows it — it avoids ever distributing the storage account key.

Azure SQL authentication — the full picture

- ▶ **SQL authentication** — username and password stored in the database engine itself; the legacy, least-preferred option.
- ▶ **Microsoft Entra authentication** — centrally managed identity, supports MFA, and integrates with Conditional Access.
- ▶ **Microsoft Entra-only authentication** can be enforced tenant-wide, disabling SQL authentication entirely for a server.
- ▶ **Managed identity connections** from an app to Azure SQL are the gold-standard combination of Domain 1 and Domain 2 content.

Memory Hook

🚩 "The Vault, The Table, The Wire"

Three physical objects, in the exam's own domain order.



Vault — Storage accounts: firewall rules, SAS access policies, Defender for Storage



Table — Databases: platform security, auditing, Defender for Databases



Wire — Networking, inside-out: NSG → VWAN → VPN → Private Access → Private Link → Firewall → Watcher

Flashcards — round 1

Q

Give a SQL database a private IP with zero public exposure — which feature?

A

Private Endpoint, backed by Private Link.

Q

Remote worker needs one internal LOB app, nothing else — best fit?

A

Microsoft Entra Private Access.

Q

Which tool reveals the actual effective NSG rule on a NIC?

A

Azure Network Watcher — effective security rules.

Q

ASG vs NSG — what's the real difference?

A

NSG is the rule set; ASG is a logical VM/NIC grouping the rules can target by name.

Flashcards — round 2

Q

Which SQL feature keeps data encrypted even in memory and query results?

A

Always Encrypted.

Q

Central policy enforcement across dozens of VNets and subscriptions?

A

Azure Virtual Network Manager.

Q

Managed L3–L7 firewall with threat-intel filtering, deployed centrally?

A

Azure Firewall, typically in a secured Virtual WAN hub.

Q

Which Defender plan flags SQL injection attempts?

A

Defender for Databases.

Quick quiz — Domain 2

1. What replaces SQL logins to eliminate credential sprawl?
→ *Microsoft Entra authentication for Azure SQL*
2. Which control limits what non-privileged users see without altering stored data?
→ *Dynamic data masking*
3. What's needed alongside a private endpoint to avoid still resolving to a public IP?
→ *A private DNS zone*
4. Which Azure WAN feature routes hub traffic through an integrated firewall?
→ *Secured hub (Virtual WAN)*
5. Where do NSG flow logs typically get analyzed at scale?
→ *A SIEM / Sentinel, via Network Watcher flow logs*

Domain 2 — what to remember



This is the exam's heaviest domain — expect the most questions here, spanning storage, databases, and every network layer.



Private-by-default is the recurring theme: private endpoints for PaaS, Entra Private Access for apps, firewalls at the boundary.



Every network control has a specific job — NSG for subnet rules, Firewall for centralized inspection, Watcher for proving what actually happened.



When two controls both look plausible, match the scenario's verb ("access one app" vs. "hide a PaaS endpoint") to the control built for that exact job.

3

DOMAIN 3

Secure Compute + AI Security

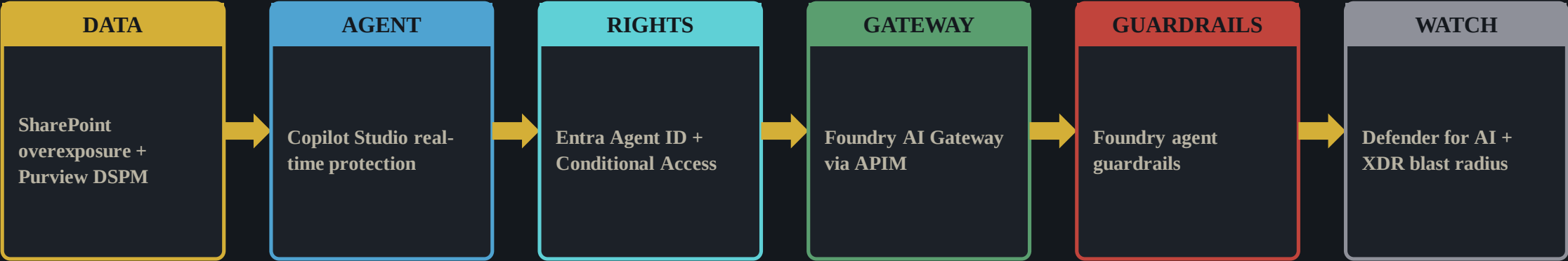
VMs, containers, and web apps — plus the domain's headline act: securing Copilot, agents, and Foundry AI workloads.

20–25% OF EXAM

Why this sub-section matters most

- ▶ **This is the block that does not exist on AZ-500 at all — every bullet in it is genuinely new material.**
- ▶ **Microsoft Copilot risk, Purview DSPM for AI, Entra Agent ID, Defender for AI Service, and the Foundry AI Gateway are unique to SC-500.**
- ▶ **Even candidates who've held AZ-500 for years are starting from zero on this specific content.**
- ▶ **Treat the next several topics as first-priority study material, not a footnote to the rest of Domain 3.**

The AI-security pipeline — D.A.R.G.E.M.



Follow one prompt from data to dashboard — every stage on this line has its own exam objective.

Memory Hook

▮ D.A.R.G.E.M. — the AI security assembly line

Six stations on a conveyor belt, in the order a prompt actually travels.

D Data exposure check — SharePoint overexposure + Purview DSPM

A Agent runtime protection — Copilot Studio real-time protection

R Rights via Entra Agent ID — Conditional Access on the agent's own identity

G Gateway control — Foundry AI Gateway deployed in API Management

E Enforcement — Foundry agent guardrails

SharePoint overexposure

- Identifies files and sites shared more broadly than intended — "anyone in the organization," or worse, external links.
- Overexposure becomes dangerous the moment Copilot can index and surface that content to any user who simply asks the right question.
- This isn't a new SharePoint problem — it's an old SharePoint problem that AI made urgent again.
- Remediation typically means tightening sharing scope and auditing existing broad links, not disabling Copilot.

NOTE

A file shared "for anyone with the link" three years ago is invisible risk — until an AI agent can read it on demand and repeat its contents to whoever asks.

Microsoft Purview DSPM for AI

- ▶ **Data Security Posture Management purpose-built for AI: surfaces what Copilot and AI apps can see, not just where data physically lives.**
- ▶ **Generates risk reports specific to AI interactions — prompts, responses, and referenced content.**
- ▶ **Pairs directly with SharePoint overexposure findings to prioritize which exposure actually matters for AI risk.**
- ▶ **Distinct from classic Purview data classification, which focuses on where sensitive data sits rather than what an AI can do with it.**

Real-time protection for Copilot Studio agents

- ▶ Runtime guardrails applied to custom agents built in Copilot Studio, as they actually run — not just at design time.
- ▶ Catches prompt injection attempts and unsafe output as they happen, rather than relying solely on pre-deployment review.
- ▶ Complements design-time testing; the exam distinguishes runtime protection from build-time validation.
- ▶ Configured per agent, allowing different sensitivity levels for different use cases.

Microsoft Entra Agent ID

- ▶ AI agents now receive their own identity object in Microsoft Entra — exactly like a user or a service principal.
- ▶ That identity can be governed by Conditional Access: require specific conditions before an agent can act.
- ▶ Agent identities can be scoped, monitored, and disabled independently of the humans who built them.
- ▶ This is the foundation everything else in the AI pipeline builds on — without an identity, there's nothing to apply policy to.

Conditional Access for Entra Agent ID

- ▶ The same Conditional Access engine from Domain 1 now extends to agent identities, not just human sign-ins.
- ▶ Policies can restrict which resources an agent can reach, from which network location, under which risk conditions.
- ▶ This is the direct technical link between Domain 1's identity content and Domain 3's AI content — expect the exam to test that connection.
- ▶ An agent without a Conditional Access policy is effectively unrestricted — treat the absence of policy as the risk finding.

Defender XDR blast-radius analysis

- ▶ If an agent's identity were compromised, what could it actually reach? XDR maps that graph explicitly.
- ▶ Goes beyond a simple permission list — traces real reachability across connected resources and delegated permissions.
- ▶ Lets a security team prioritize which agent identities represent the highest actual risk, not just the broadest nominal permissions.
- ▶ A natural complement to Entra Agent ID — one grants scoped access, the other proves how scoped it really turned out to be.

EXAM TIP

When a scenario asks "what could an attacker reach if this agent were compromised," the answer is Defender XDR blast-radius analysis — not a manual permissions audit.

Foundry AI Gateway

- ▶ A control point in front of AI model endpoints, deployed through Azure API Management.
- ▶ Provides rate limiting, authentication enforcement, and centralized logging for every call to a Foundry-hosted model.
- ▶ Lets security teams apply consistent policy across many models and many consuming applications from one place.
- ▶ The exam frames this as the network-boundary equivalent of a private endpoint — but for AI model traffic specifically.

Defender for AI Service

- ▶ A dedicated Defender for Cloud workload protection plan, purpose-built for AI resources.
- ▶ Enabled the same way as Defender for Storage or Defender for Databases — a per-resource-type plan toggle.
- ▶ Detects threats specific to AI workloads: prompt injection patterns, model abuse, and anomalous inference activity.
- ▶ Findings roll up into the same Defender for Cloud dashboard as every other workload protection plan.

Foundry agent guardrails

- ▶ **Configurable content and behavior boundaries applied directly to agents built in Microsoft Foundry.**
- ▶ **Distinct from Copilot Studio's real-time protection — Foundry guardrails govern agents built on the broader Foundry platform.**
- ▶ **Can restrict topics, enforce output formatting, or block categories of unsafe content before a response ever reaches a user.**
- ▶ **Configured per agent or applied as a baseline across a Foundry project.**

Monitoring & lifecycle management

Data and AI security dashboard

- ▶ The single-pane rollup inside Defender for Cloud for everything in the AI-security pipeline.
- ▶ Surfaces Purview DSPM findings, Defender for AI Service alerts, and agent risk in one view.
- ▶ The go-to answer when a scenario asks "where do I see AI risk across the whole tenant?"

Managing agents in the M365 admin center

- ▶ Day-2 lifecycle control: who can publish agents, where they're allowed to run.
- ▶ Distinct from Copilot Studio's build-time authoring experience — this is tenant-wide governance.
- ▶ The right answer for "restrict who in the org can publish a new Copilot agent."

AI security — matching the verb to the objective

- ▶ Is the scenario about what an agent can see? → Purview DSPM / SharePoint overexposure.
- ▶ Is it about what an agent can do? → Entra Agent ID + Conditional Access.
- ▶ Is it about what happens if the agent is compromised? → Defender XDR blast-radius analysis.
- ▶ Is it about controlling access to the underlying model? → Foundry AI Gateway.

EXAM TIP

Matching the scenario's verb — see, do, or compromised — to the right objective solves most of this section's harder questions.

Virtual machine security — disk encryption

- ▶ **Azure Disk Encryption applies guest-OS-level encryption (BitLocker on Windows, DM-Crypt on Linux).**
- ▶ **This layers on top of platform-managed storage encryption, which is already on by default underneath.**
- ▶ **Encryption keys can be customer-managed via Key Vault for organizations requiring full key control.**
- ▶ **Applies to both OS and data disks; know that the two can be configured independently.**

Azure Bastion & just-in-time VM access

- ▶ **Azure Bastion provides browser-based RDP/SSH — no public IP is ever exposed on the target VM.**
- ▶ **Just-in-time (JIT) VM access keeps management ports closed by default, opening them on-demand for a limited, requested window.**
- ▶ **The two combine well: Bastion removes the need for a public IP at all, JIT limits exposure for the cases where direct access is still used.**
- ▶ **Both directly target the same root risk — internet-facing management ports — from different angles.**

Azure Arc & Defender for Servers

- ▶ **Azure Arc extends Azure management — including Defender for Servers and Azure Policy — to on-premises and multicloud machines.**
- ▶ **Onboarding a non-Azure server through Arc makes it a first-class citizen for the same security tooling as native Azure VMs.**
- ▶ **Defender for Servers then provides vulnerability scanning and endpoint detection and response (EDR) across both native and Arc-onboarded machines.**
- ▶ **This is the exam's standard path for "we have on-prem or AWS/GCP VMs we need Defender coverage on."**

Agentless scanning & VM security features

- ▶ **Agentless scanning** inspects VM disks for vulnerabilities and malware without installing any software inside the guest OS.
- ▶ **Secure boot** and **virtual TPM (vTPM)** are core components of Trusted Launch VMs, guarding against rootkits and boot-level tampering.
- ▶ **Integrity monitoring** continuously validates that boot components haven't been altered since the last known-good state.
- ▶ **Azure Machine Configuration** (formerly Guest Configuration) enforces in-guest policy — auditing or remediating settings inside the OS itself.

Defender for Containers

- ▶ **Detects misconfigurations and runtime threats across the full container stack.**
- ▶ **Covers Azure Kubernetes Service (AKS), Azure Container Registry (ACR), Azure Container Instances (ACI), and Container Apps.**
- ▶ **Registry scanning catches vulnerable base images before they're ever deployed.**
- ▶ **Runtime protection detects anomalous process activity and privilege escalation inside running containers.**

Application platform services

- ▶ **Azure Functions and Logic Apps security centers on authentication enforcement and restricting network access (VNet integration, private endpoints).**
- ▶ **App Service security follows the same pattern — managed identity for outbound calls, restricted inbound access, easy auth for inbound identity.**
- ▶ **Web Application Firewall (WAF) applies OWASP rule sets in front of Application Gateway or Front Door to block common web attacks.**
- ▶ **API Management protects back-end APIs with subscription keys, OAuth token validation, and configurable rate limits.**

Case walkthrough — rolling out a new Copilot agent

- ▶ **Step 1: run Purview DSPM for AI against the target SharePoint sites — fix overexposed sharing before the agent goes live.**
- ▶ **Step 2: register the agent's identity in Entra Agent ID and attach a Conditional Access policy scoping what it can reach.**
- ▶ **Step 3: enable real-time protection in Copilot Studio so runtime prompt-injection attempts are caught, not just design-time ones.**
- ▶ **Step 4: turn on Defender for AI Service and check the Data and AI security dashboard before declaring the rollout complete.**

EXAM TIP

This four-step order — data, identity, runtime, monitoring — is a reliable template for any "how would you secure a new AI rollout" scenario question.

AI security — objective cheat sheet

If the scenario is about...	The objective is...
Over-shared files an agent could read	SharePoint overexposure + Purview DSPM for AI
An agent's runtime behavior going wrong	Copilot Studio real-time protection
Restricting what an agent identity can access	Entra Agent ID + Conditional Access
What a compromised agent could reach	Defender XDR blast-radius analysis
Rate limiting or auth on a model endpoint	Foundry AI Gateway (via APIM)
Content/behavior boundaries on a Foundry agent	Foundry agent guardrails
One dashboard for all AI risk, tenant-wide	Data and AI security dashboard
Who can publish a new agent org-wide	Agent management, M365 admin center

Memory Hook

▮ Recap — D.A.R.G.E.M. still carries the domain

Before moving to Domain 4, run the six letters again from memory.

D Data exposure — SharePoint overexposure, Purview DSPM

A Agent protection — Copilot Studio real-time runtime guardrails

R Rights — Entra Agent ID governed by Conditional Access

G Gateway — Foundry AI Gateway in API Management

E Enforcement — Foundry agent guardrails

Flashcards — round 1

Q

Tool that maps what a compromised agent identity could reach?

A

Microsoft Defender XDR blast-radius analysis.

Q

Which surface flags risky over-sharing Copilot could expose?

A

Purview DSPM for AI, paired with SharePoint overexposure findings.

Q

VM management with zero standing open RDP/SSH ports?

A

Just-in-time (JIT) VM access, ideally with Azure Bastion.

Q

Where do you configure rate limiting for a Foundry model endpoint?

A

Foundry AI Gateway, deployed through Azure API Management.

Flashcards — round 2

Q

Which identity object lets Conditional Access govern an AI agent?

A

Microsoft Entra Agent ID.

Q

Which control extends Defender for Servers to an on-prem VM?

A

Azure Arc onboarding.

Q

Which VM feature detects boot-level tampering continuously?

A

Integrity monitoring, part of Trusted Launch.

Q

Where do you see AI risk findings rolled up tenant-wide?

A

The Data and AI security dashboard in Defender for Cloud.

Flashcards — round 3

Q

Which Defender plan is specific to AI resources?

A

Defender for AI Service.

Q

Where do you restrict who can publish a new Copilot agent org-wide?

A

The Microsoft 365 admin center, agent management.

Q

Which container security plan covers AKS, ACR, ACI, and Container Apps together?

A

Defender for Containers.

Q

What guards back-end APIs behind API Management from abuse?

A

Subscription keys, OAuth validation, and configurable rate limits.

Quick quiz — Domain 3

1. What differs between real-time protection and design-time review for Copilot Studio agents?
→ *Real-time protection guards the running agent; design-time review happens before deployment*
2. Which encryption layers on top of platform-managed storage encryption for a VM disk?
→ *Azure Disk Encryption (guest-OS level)*
3. Which capability scans VM disks without installing anything in the guest OS?
→ *Agentless scanning*
4. Which control blocks unsafe or off-topic output from a Foundry-built agent?
→ *Foundry agent guardrails*
5. Which tool would you enable to catch a vulnerable base image before deployment?
→ *Defender for Containers registry scanning*

Domain 3 — what to remember



This domain's AI-security content is entirely new territory — give it more study time than its blueprint weight suggests.



D.A.R.G.E.M. traces one prompt's entire journey: data exposure, agent runtime, identity rights, gateway control, guardrails, monitoring.



Entra Agent ID is the connective tissue between Domain 1 (identity) and Domain 3 (AI) — agents get governed exactly like users.



The rest of Domain 3 — VMs, containers, App Service — closely tracks familiar AZ-500 territory: least exposure, managed identity, runtime scanning.

4

DOMAIN 4

Security Posture & Monitoring

Seeing everything at once: posture management, the SIEM, and the AI copilot that helps you triage it all.

20–25% OF EXAM

Defender CSPM & compliance

- **Defender Cloud Security Posture Management provides posture scoring, attack-path analysis, and secret scanning across the environment.**
- **Attack-path analysis chains together individually minor misconfigurations to show how an attacker could actually reach a sensitive resource.**
- **Regulatory compliance evaluation maps configuration against named frameworks — NIST, ISO 27001, PCI-DSS.**
- **Posture score is continuously recalculated, giving a live view rather than a point-in-time snapshot.**

Workload protection plans

- ▶ Each resource type gets its own Defender plan, toggled on independently: Servers, Storage, Databases, Containers, Key Vault, AI Service, and more.
- ▶ Enabling one plan doesn't enable the others — a common exam gotcha when a scenario says protection "isn't working" for a specific resource type.
- ▶ Plans can be enabled at the subscription level for broad coverage or scoped more narrowly where cost is a concern.
- ▶ Findings from every enabled plan roll up into the same unified Defender for Cloud dashboard.

COMMON TRAP

"We enabled Defender for Cloud but aren't seeing container alerts" almost always means the Defender for Containers plan specifically was never turned on — enabling the platform doesn't enable every plan automatically.

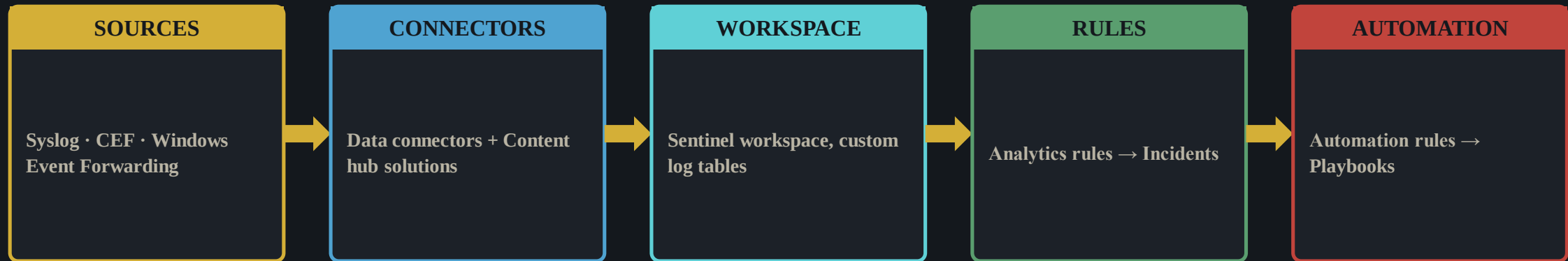
Multicloud connectors, vulnerability management & EASM

- ▶ **Multicloud connectors bring AWS and GCP accounts into the same Defender for Cloud view alongside Azure resources.**
- ▶ **Microsoft Defender Vulnerability Management delivers CVE-level scanning specifically for Azure VMs.**
- ▶ **Defender External Attack Surface Management (EASM) discovers internet-facing assets an organization didn't know it had.**
- ▶ **Three distinct jobs on one platform: multicloud visibility, VM-level CVE detail, and outside-in asset discovery.**

EXAM TIP

"We don't know all our internet-facing assets" → EASM. "We want AWS findings alongside Azure findings in one dashboard" → multicloud connector.
"We need a CVE list for our VM fleet" → Vulnerability Management.

The Sentinel pipeline



From a raw log source on the left to an automated response on the right — every Sentinel objective sits somewhere on this line.

Sentinel workspaces & the content hub

- ▶ **Create and connect Sentinel workspaces, then assign RBAC roles: Reader, Responder, Contributor, each with progressively broader capability.**
- ▶ **The content hub delivers pre-packaged solutions per product or vendor — connectors, analytics rules, and workbooks bundled together.**
- ▶ **Installing a content hub solution is almost always faster and more maintainable than hand-building the equivalent from scratch.**
- ▶ **Workspace design decisions (single vs. multiple workspaces) affect both cost and cross-team data access.**

Event collection — two paths for Windows

Data Collection Rules (DCRs)

- ▶ The modern, cloud-native path for Windows Security event collection.
- ▶ Fine-grained control over exactly which event types and fields get ingested.
- ▶ Preferred for greenfield deployments and Azure Monitor Agent-based collection.

Windows Event Forwarding (WEF)

- ▶ The legacy path, still relevant for hybrid and heavily on-premises estates.
- ▶ Uses native Windows event subscription infrastructure rather than an Azure-native agent.
- ▶ The right answer when a scenario specifically describes a large legacy Windows environment.

Data connectors, syslog/CEF, and custom log tables

- ▶ Data connectors for native Azure resources are largely a config-and-enable exercise — most of the heavy lifting is pre-built.
- ▶ Syslog and Common Event Format (CEF) collection is the standard route for non-Microsoft network and security appliances.
- ▶ Custom log tables handle data that doesn't fit any built-in schema — define your own structure for ingestion.
- ▶ Choosing the right ingestion method up front avoids costly reprocessing later.

Automation rules, playbooks & retention

- ▶ Automation rules triage and route an incident the moment it's created — assign an owner, apply a tag, suppress a known-noisy pattern.
- ▶ Playbooks (built on Logic Apps) execute the actual response steps: isolate a host, disable an account, notify a team channel.
- ▶ An automation rule can call one or more playbooks as part of its response — know that the rule decides when, the playbook decides what.
- ▶ Data retention is configurable per table in the Sentinel data store, split between interactive (fast, expensive) and long-term/archive (slow, cheap) tiers.

Microsoft Purview Audit in Defender XDR

- ▶ Purview Audit logs can be queried directly from within Defender XDR during an investigation.
- ▶ Cross-references user and admin activity logs against the technical signals Sentinel and Defender already captured.
- ▶ Useful for answering "what did this specific user actually do" without switching tools mid-investigation.
- ▶ Bridges compliance-oriented audit data with security-oriented incident data in a single pane.

Microsoft Security Copilot

Workspaces & permissions

- ▶ Workspaces are the tenant-level container for Security Copilot sessions and configuration.
- ▶ Permissions and roles control who can run prompts, manage plugins, and view session history.
- ▶ Set up once at the tenant level before any analyst starts using Copilot day to day.

Plugins & agents

- ▶ Plugins connect Security Copilot to Defender, Sentinel, Entra, and select third-party sources.
- ▶ Microsoft agents and Security Store agents are pre-built or custom autonomous agents that run investigative or response tasks inside Copilot.
- ▶ The right answer for "automate a repeatable triage step without writing a playbook."

Defender for Cloud — workload protection plans at a glance

Plan	Protects
Defender for Servers	VMs — vulnerability scanning, EDR, JIT access
Defender for Storage	Blob malware scanning, sensitive-data threat detection
Defender for Databases	SQL, Cosmos DB, open-source relational engines
Defender for Containers	AKS, ACR, ACI, Container Apps
Defender for Key Vault	Runtime threat detection on vault operations
Defender for AI Service	AI workloads — prompt injection, model abuse

Each plan is an independent toggle. Enabling Defender for Cloud itself does not turn any of these on automatically.

Sentinel RBAC — the three core roles

- ▶ **Sentinel Reader** — view data, incidents, and workbooks; cannot change configuration or respond to incidents.
- ▶ **Sentinel Responder** — everything a Reader can do, plus manage incidents: assign, close, comment, change status.
- ▶ **Sentinel Contributor** — everything a Responder can do, plus create and edit analytics rules, playbooks, and workbooks.
- ▶ **Assign the narrowest role that lets someone do their job** — a SOC analyst triaging incidents rarely needs Contributor.

Memory Hook

🚩 C.S.I. — Cloud, SIEM, Intelligence

Three tools, like a detective's kit: a magnifying glass, a case file, and an assistant.

C Cloud posture — Defender for Cloud: CSPM, workload plans, multicloud, EASM

S SIEM — Microsoft Sentinel: connectors, analytics rules, playbooks, retention

I Intelligence — Microsoft Security Copilot: workspaces, plugins, agents

Flashcards — round 1

Q

Best tool to find internet-facing assets you never knew existed?

A

Defender EASM (External Attack Surface Management).

Q

Windows Security event collection on a hybrid, legacy-heavy estate?

A

Windows Event Forwarding (WEF) — DCRs for modern/cloud-native setups.

Q

What actually executes response steps after an incident triggers?

A

A playbook (Logic App), called by an automation rule.

Q

Where do you manage who can enable plugins in Security Copilot?

A

Security Copilot workspace permissions and roles.

Flashcards — round 2

Q

Attack-path analysis lives in which Defender for Cloud capability?

A

Defender CSPM.

Q

What brings AWS and GCP findings into the same dashboard as Azure?

A

Defender for Cloud multicloud connectors.

Q

"We enabled Defender for Cloud but see no container alerts" — why?

A

The Defender for Containers plan specifically wasn't turned on.

Q

Which Sentinel tier balances cost against fast query access?

A

Interactive vs. long-term/archive retention tiers.

Quick quiz — Domain 4

1. Which capability chains minor misconfigurations into a real attack path?
→ *Defender CSPM attack-path analysis*
2. Which plan delivers CVE-level detail specifically for Azure VMs?
→ *Microsoft Defender Vulnerability Management*
3. Where do you install a pre-packaged connector-plus-rules bundle in Sentinel?
→ *The content hub*
4. What's the standard ingestion route for a non-Microsoft firewall appliance?
→ *Syslog / CEF collection*
5. Which Security Copilot feature automates a repeatable triage task?
→ *A Microsoft agent or Security Store agent*

Domain 4 — what to remember



Defender for Cloud, Sentinel, and Security Copilot form one continuous chain: see posture, collect and correlate events, then triage with AI assistance.



Workload protection plans are independent toggles — enabling Defender for Cloud doesn't automatically enable every resource-specific plan.



Know the three distinct multicloud/vulnerability/EASM jobs — they get confused constantly on this exam.



In Sentinel, automation rules decide when to respond; playbooks decide what the response actually does.

R

DOMAIN R

Rapid-Recall Drill

Fifteen closed-book questions spanning all four domains. Say each answer out loud before revealing it.

15 QUESTIONS

What replaces a stored connection string in almost every "correct" SC-500 answer?

ANSWER

A managed identity token flow.

Which lock type blocks configuration changes, not just deletion?

ANSWER

ReadOnly resource lock.

Which Entra tool converts standing admin rights into time-boxed, approved activations?

ANSWER

Privileged Identity Management (PIM).

What identifies over-shared SharePoint content before Copilot can surface it?

ANSWER

Purview DSPM for AI, paired with SharePoint overexposure detection.

What gives an AI agent its own Conditional-Access-governed identity?

ANSWER

Microsoft Entra Agent ID.

Which Defender XDR capability shows what a compromised agent identity could reach?

ANSWER

Blast-radius analysis.

Where do rate limiting and auth for Foundry model endpoints get configured?

ANSWER

Foundry AI Gateway, deployed via Azure API Management.

What gives a PaaS resource a private IP inside your VNet?

ANSWER

Private Endpoint, backed by Private Link.

Best fit for a remote worker needing zero-trust access to one internal app, no VPN client?

ANSWER

Microsoft Entra Private Access.

Which tool discovers internet-facing assets an org didn't know it had?

ANSWER

Defender EASM.

Which Sentinel objects triage/route an incident vs. which ones execute the response?

ANSWER

Automation rules triage and route; playbooks (Logic Apps) execute.

System-assigned vs. user-assigned managed identity — which survives resource deletion?

ANSWER

User-assigned — it's a standalone, shareable object.

Which Sentinel role can manage incidents but not edit analytics rules?

ANSWER

Sentinel Responder.

Which SAS type avoids ever distributing the storage account key?

ANSWER

User delegation SAS.

Which Defender for Cloud capability chains small misconfigurations into a real attack path?

ANSWER

Defender CSPM attack-path analysis.

G

DOMAIN G

Glossary

The acronyms this exam assumes you already speak fluently.

KEY TERMS

Identity & governance terms



Privileged Identity Management — just-in-time, time-boxed role activation.



Role-Based Access Control — permission assignment via built-in or custom roles.



Cloud Security Posture Management — continuous configuration risk scoring.



Multi-User Authorization — a second approver required for critical backup actions.

Networking terms

NSG / ASG

Network / Application Security Group — subnet-and-NIC-level traffic rules.

VWAN

Virtual WAN — managed hub-and-spoke network backbone.

WAF

Web Application Firewall — OWASP-based filtering in front of a web app.

APIM

API Management — the gateway layer protecting back-end APIs.

AI security terms

D DSPM

Data Security Posture Management — Purview's risk view of what data AI can reach.

X XDR

Extended Detection and Response — Defender's cross-signal investigation platform.

A Agent ID

The Entra identity object now assigned to AI agents, not just users.

F Foundry

Microsoft's platform for building and deploying AI models and agents.

Compute & monitoring terms

J JIT

Just-In-Time VM access — management ports open only on request, briefly.

V vTPM

Virtual Trusted Platform Module — part of Trusted Launch VM security.

E EASM

External Attack Surface Management — discovers unknown internet-facing assets.

S SIEM

Security Information and Event Management — Sentinel's core function.

More terms worth knowing



Transparent Data Encryption — automatic at-rest encryption for Azure SQL.



Data Collection Rule — the modern path for routing events into Sentinel.



Windows Event Forwarding — the legacy path for hybrid Windows event collection.



Endpoint Detection and Response — Defender for Servers' runtime protection.

Pitfalls that cross every domain

- ▶ Reading a control's name and assuming its job — "Defender for Cloud" is a platform, not a single alert; know which specific plan does what.
- ▶ Picking the technically-correct-but-broader option over the least-privilege one — the exam almost always prefers narrower.
- ▶ Forgetting that enabling a parent service doesn't enable every child plan or feature underneath it automatically.
- ▶ Treating "agent" as a vague AI buzzword instead of a specific governed identity with its own Conditional Access surface.

COMMON TRAP

If an answer choice would require a standing credential, a permanently open port, or a broader-than-needed role, it is very likely the wrong answer — regardless of how familiar or convenient it sounds.

What happens next



Beta scoring delay

If you sat the beta exam, expect roughly ten weeks before your score is released — this is normal, not a sign of trouble.



Annual renewal

SC-500 renews annually through a free assessment on Microsoft Learn — no need to resit the full exam.



Keep building

Hands-on time in a test subscription — enabling Defender plans, walking through Entra Agent ID — cements this material far faster than re-reading it.

The pattern behind every right answer

Coming from AZ-500

Skim Domains 1, 2, 4 for refresh. Spend new hours on Domain 3's AI-security bullets and Entra Private Access — the two biggest deltas.

New to Azure security

Budget 10–14 weeks. Build Domains 1 and 2 first — identity and networking underpin everything that follows.

Studying in the beta window

Expect roughly an 80% discount, but a scoring delay of about ten weeks after beta closes. Plan your timeline accordingly.

Two days before the exam

Run this deck's diagrams and the 15-question recall drill from memory, out loud. Anything you hesitate on goes back into its Domain section.

LAST WORD · Every right-answer pattern on this exam rewards least privilege, no standing credentials, and private-by-default networking. When two options both look valid, the one that removes a standing secret, an open port, or a broad permission is almost always intended.